

CAPSTONE DELIVERABLE 1

ShieldAudit

A CCPA Cybersecurity Audit Platform

Platform Overview and 14-Week Pace Guide

Submitted: May 11, 2026

Course: MS Cybersecurity Engineering Capstone

Institution: University of San Diego, Shiley-Marcos School of Engineering

Advisor: Professor Haydar Majeed, PhD, CISM, CISA, c|CISO

Team: Erwin Bruno (Product Owner) | Bobby Dai (Product Owner) | Noah Shaffer (Engineer)

ApexShield LLC (Erwin Bruno, Bobby Dai) | LockRidge (Noah Shaffer)

1. Executive Summary

ShieldAudit is a web-based CCPA cybersecurity audit platform built to help California-covered businesses complete the annual audit required under Cal. Code Regs. tit. 11, Sections 7120 through 7124. The regulation took effect January 1, 2026, and imposes structured cybersecurity audit requirements on for-profit businesses that meet defined revenue and data processing thresholds. Non-compliance carries civil penalties ranging from \$2,663 to \$7,988 per violation, per consumer record, per day.

ShieldAudit eliminates the manual, document-heavy process of conducting a CCPA cybersecurity audit by guiding users through four sequential modules: an eligibility screener, a 40-question assessment across 18 CPPA-mandated components, a scoring dashboard with penalty exposure estimates, and an automated report generator that produces the two legally required submission documents. The platform is designed for two commercial channels: direct audit engagements by ApexShield LLC at \$9,500 per client, and white-label licensing to MSPs, law firms, and accounting firms at \$300 to \$500 per completed assessment through Stripe billing.

2. Problem Statement

The CCPA cybersecurity audit requirement is new, mandatory, and complex. Most businesses subject to it have no internal process for producing the two required documents: a Cybersecurity Audit Report (Section 7123) covering 18 specific components and an Executive Certification (Section 7124) signed under penalty of perjury by the executive directly responsible for cybersecurity compliance.

There is currently no purpose-built tool for this specific regulation. General compliance platforms such as Vanta, Drata, or Tugboat Logic address multi-framework automation (SOC 2, ISO 27001, HIPAA) but do not produce the CPPA-specific documents required for submission via cpa.ca.gov. Covered businesses face real consequences:

- Penalties of \$2,663 to \$7,988 per violation, per consumer record, per day
- Submission deadlines beginning April 1, 2028 for businesses over \$100M revenue
- Certification requirements that expose named executives to personal liability under penalty of perjury
- No off-the-shelf tool produces a CPPA-compliant Document A or Document B

ShieldAudit fills this gap as the first purpose-built CCPA cybersecurity audit compliance platform.

3. Platform Overview

3.1 Coverage Triggers

ShieldAudit applies the OR logic prescribed by the regulation. A business is covered if it is a for-profit entity that collects California resident personal information AND meets any one of the following four triggers:

- Annual gross revenue exceeding \$26,625,000
- Processes personal information of 250,000 or more California consumers or households per year
- Processes sensitive personal information of 50,000 or more California consumers per year
- Derives 50% or more of annual revenue from selling or sharing personal information

The eligibility screener in Module 1 evaluates all four triggers and outputs the specific trigger that fires, along with the applicable submission deadline.

3.2 Submission Deadlines

The first auditable period is calendar year 2027. Submission deadlines are tiered by revenue:

- April 1, 2028: Businesses with annual gross revenue over \$100 million
- April 1, 2029: Businesses with annual gross revenue between \$50 million and \$100 million
- April 1, 2030: Businesses with annual gross revenue under \$50 million

3.3 Four-Module Workflow

The platform enforces a linear, non-skippable four-module workflow. Each module must be completed before the next becomes available.

- **Five questions evaluate the four coverage triggers and California nexus. Output is a binary Covered/Not Covered result with the specific trigger cited and the applicable CPPA submission deadline.** Module 1 (Eligibility Screener):
- **Forty structured questions across 18 CPPA-mandated components. Each question accepts Yes, Partial, No, or Not Applicable. Evidence notes and auditor notes fields accompany every question. Auto-save is active throughout, and assessments can be paused and resumed.** Module 2 (Audit Assessment):
- **Per-component traffic light scores (red under 50, yellow 50 to 79, green 80 and above), an overall program score from 0 to 100, a penalty exposure estimate using consumer record count multiplied by the \$5,325 midpoint penalty multiplied by estimated exposure days, a CPPA submission deadline countdown, and the top five critical gaps ranked by risk weight.** Module 3 (Scoring Dashboard):
- **One-button generation of both required CPPA submission documents. Both export as PDF and DOCX.** Module 4 (Report Generator):

4. The 18 CCPA-Mandated Audit Components

Section 7123 of Title 11 of the California Code of Regulations mandates that the Cybersecurity Audit Report address 18 specific components. ShieldAudit covers all 18 with a total of 40 assessment questions. The question count per component reflects relative regulatory complexity and risk weight.

#	Component	Questions	Scope Description
1	Data Inventory	2	Document all personal data flows, sources, and retention schedules
2	Access Controls	3	Role-based access, least privilege, access review processes
3	Authentication	2	MFA, password policies, session management
4	Data Encryption	3	Encryption at rest and in transit for personal information
5	Network Security	3	Firewalls, segmentation, intrusion detection/prevention
6	Physical Security	1	Data center access controls, device management
7	Software Security	3	SDLC security, patch management, code review practices
8	Data Retention	2	Retention schedules, secure deletion, minimization
9	Vendor Management	2	Third-party risk assessments, DPAs, vendor SLAs
10	Incident Response	3	IR plan, tabletop exercises, response timelines
11	Employee Training	2	Security awareness, role-based training, records
12	Audit Logging	2	Log collection, retention, review, and alerting
13	Vulnerability Management	3	Scanning cadence, patch SLAs, remediation tracking
14	Risk Assessment Process	3	Annual risk assessment, methodology, documentation
15	Breach Notification	2	CCPA breach notification procedures and timelines
16	Third-Party Data Sharing	2	Data sharing agreements, purpose limitation, tracking
17	Data Minimization	2	Collection limitation, purpose binding, anonymization
18	Program Governance	3	Cybersecurity program ownership, budget, board reporting

5. Required Submission Documents

5.1 Document A: Cybersecurity Audit Report (Section 7123)

Document A is the primary audit record submitted to the CCPA. ShieldAudit auto-generates this document with all required fields populated from the assessment answers. It includes:

- Business identification and audit period
- Systems and data flows in scope
- Auditor independence statement
- Findings for all 18 components, including evidence cited, identified gaps, and remediation timelines
- Breach notifications issued during the audit period
- Titles of up to three individuals responsible for the program
- Audit methodology disclosure (NIST CSF 2.0 or CIS Controls v8.1)

5.2 Document B: Executive Certification (Section 7124)

Document B is the certification signed under penalty of perjury by the executive directly responsible for cybersecurity audit compliance. ShieldAudit generates this document with all required fields and provides CCPA submission instructions. It includes:

- Certification that an independent audit was completed
- Certification that the auditor was not subject to undue influence
- Business name, signer name, signer title, and date
- Perjury declaration and CCPA submission instructions via cpa.ca.gov

6. Business Model and Vanta Compliance Reference

Professor Majeed recommended studying Vanta Compliance as a business model reference. The comparison below illustrates how ShieldAudit is positioned relative to Vanta, and where the two platforms differ strategically.

Dimension	Vanta Compliance	ShieldAudit
Core Value Proposition	Automates SOC 2, ISO 27001, HIPAA, and other compliance frameworks via continuous monitoring	Guides CCPA-covered businesses through the mandatory annual cybersecurity audit required by Cal. Code Regs. tit. 11, Sections 7120-7124
Target Regulation	Multiple frameworks (SOC 2, ISO 27001, GDPR, HIPAA)	Single regulation: CCPA cybersecurity audit requirements (2026)

Dimension	Vanta Compliance	ShieldAudit
Buyer Segments	Mid-market SaaS companies needing compliance for sales/procurement	ApexShield LLC (direct, \$9,500/engagement) and white-label resellers: MSPs, law firms, accounting firms (\$300-\$500/assessment)
Revenue Model	Annual SaaS subscription per framework	Per-assessment Stripe billing; fixed-fee for direct engagements; white-label reseller markup
Document Output	Evidence reports and audit-ready exports	Two legally mandated documents: Cybersecurity Audit Report (Section 7123) and Executive Certification (Section 7124)
Key Differentiator	Continuous automated evidence collection across cloud infrastructure	CPPA-specific compliance, penalty exposure calculator, attorney-reviewed output, and white-label reseller channel

The key takeaway from Vanta's model is that per-assessment or per-seat pricing tied to a defined compliance outcome is a proven, repeatable revenue structure. ShieldAudit adopts the same principle, applying it to a single high-stakes regulation with a hard government submission deadline, a defined penalty structure, and no existing purpose-built solution.

Vanta's approach to white-label and partner channels (allowing accountants, consultants, and MSPs to resell compliance services under their own brand) is also directly adopted. ShieldAudit's reseller channel allows partners to brand the platform and deliver completed CPPA audit packages to their clients at \$300 to \$500 per assessment.

7. Technical Architecture

The platform is built on a modern, production-ready stack chosen for developer velocity, multi-tenant isolation, and legal-grade document generation.

Layer	Technology
Frontend	React 18 + TypeScript
Styling	Tailwind CSS
Backend	Next.js API routes
Database	PostgreSQL with org_id row-level isolation
Authentication	Clerk or Auth0 (multi-tenant, admin and reseller roles)
PDF Generation	Puppeteer (server-side rendering for legal documents)
DOCX Generation	docx.js
Payments	Stripe (per-assessment billing, \$300 to \$500)
Hosting	Vercel (frontend) + Railway (backend)
File Storage	AWS S3 or Cloudflare R2 (5-year minimum retention per Section 7123)

8. 14-Week Pace Guide

The capstone runs from May 5, 2026 through August 7, 2026 across two seven-week parts. Part 1 covers platform foundations and core build. Part 2 covers report integration, billing, and pilot launch.

Wk	Dates	Phase	Key Deliverables
PART 1: FOUNDATIONS & CORE BUILD (Weeks 1-7)			
1	May 5-9	Foundation	Capstone Deliverable 1: Platform overview, pace guide submission
2	May 12-16	Foundation	Eligibility screener UI, OR logic, trigger citation, submission deadline calculator
3	May 19-23	Foundation	Org workspaces, admin/reseller roles, white-label config schema
4	May 26-30	Foundation	All 40 questions loaded in DB, assessment navigation UI, auto-save
5	Jun 2-6	Core Build	Assessment pause/resume, evidence notes field, auditor notes, status tracking
6	Jun 9-13	Core Build	Scoring engine: weighted per-component score, traffic light logic (red/yellow/green)

Wk	Dates	Phase	Key Deliverables
7	Jun 16-20	Core Build	Penalty calculator, deadline countdown, NIST CSF 2.0 alignment map
PART 2: INTEGRATION, REPORTING & PILOT (Weeks 8-14)			
8	Jun 23-27	Core Build	Scoring dashboard complete: all 5 widgets, top 5 gap ranking
9	Jun 30-Jul 4	Integration	Document A (Section 7123) PDF template, all 18 components rendered
10	Jul 7-11	Integration	Document B (Section 7124) PDF, DOCX export for both required documents
11	Jul 14-18	Integration	White-label branding on reports, subdomain routing, reseller settings page
12	Jul 21-25	Integration	Stripe billing integration, assessment lock on payment, billing dashboard
13	Jul 28-Aug 1	Pilot & Demo	CA privacy attorney sign-off, 3 pilot resellers onboarded, full QA pass
14	Aug 4-7	Pilot & Demo	Final demo, capstone presentation, USD licensing review

9. Risk Register

The following risks have been identified and mitigated as part of the project plan.

Risk	Likelihood	Impact	Mitigation
CPPA updates Section 7123 component requirements	Medium	High	Question bank and templates stored in DB, not hardcoded. Updates require config change, not code deploy.
Document A or B rejected as non-compliant by CPPA	Medium	High	CA privacy attorney review in Week 11 is a hard gate. No launch without written sign-off.
PDF formatting complexity underestimated	High	Medium	Puppeteer server-side rendering. Dedicated Document A review against Section 7123 exact requirements in Week 9.
Pilot resellers do not onboard in time	Low	Medium	Erwin recruits resellers via ApexShield relationships by Week 4.
Attorney review delays Week 13	Medium	High	Attorney engaged in Week 11, not Week 13. Two-week review window built in.
Scope creep exceeds 14-week timeline	Medium	High	MVP strictly limited to 4-module core workflow. Phase 2 features explicitly deferred.

10. Success Metrics

The following metrics will be used to evaluate whether ShieldAudit achieves its goals during the capstone period.

Metric	Target	Measurement Method
Audit completion rate	80% or higher	Track assessment status in DB from start to report generation
Time to complete audit	Under 3 hours for a prepared consultant	Log assessment start vs. report generation timestamps
Document acceptance	CA privacy attorney confirms compliance	Written attorney sign-off in Week 13
Reseller adoption	3 pilot resellers, 1 paid assessment each	Stripe records plus assessment completion records
Penalty calculator accuracy	Within 10% of manual calculation	Cross-check with pilot users in Week 13

Contact

Erwin Bruno, Product Owner | ApexShield LLC | ebruno@san Diego.edu | [linkedin.com/in/erwinvonbruno](https://www.linkedin.com/in/erwinvonbruno)

Bobby Dai, Product Owner | ApexShield LLC | jinjiedai@san Diego.edu | [linkedin.com/in/bobbydaiprofile](https://www.linkedin.com/in/bobbydaiprofile)

Noah Shaffer, Engineer | LockRidge | nshaffer@san Diego.edu | [linkedin.com/in/noahwilliamshaffer](https://www.linkedin.com/in/noahwilliamshaffer)

Document Version 1.0 | May 11, 2026 | ApexShield LLC | Confidential